

Relatório Técnico - N1

Vulnerabilidades em Aplicações Web (SaaS) - Pentesting

Disciplina: Segurança da Informação

Professor: Claudinei Dias (Ney)

Integrantes: Rafael Dobner e André H. Voigt

Data dos testes: 14/09/2026

A V1 foi criada propositalmente vulnerável para demonstrar SQL Injection, Stored XSS e CSRF. A V2 implementa JWT, bcrypt, consultas parametrizadas, validação, Helmet/CSP e token anti-CSRF.

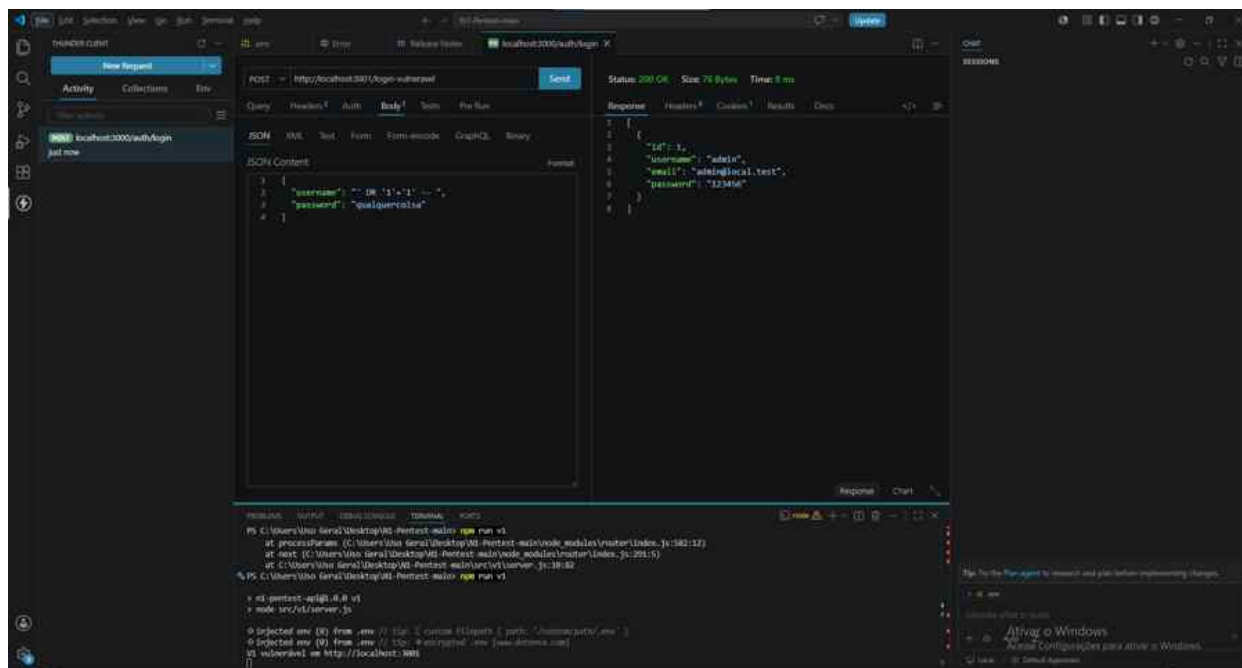


Figura 1 - SQL Injection comprovada na V1.

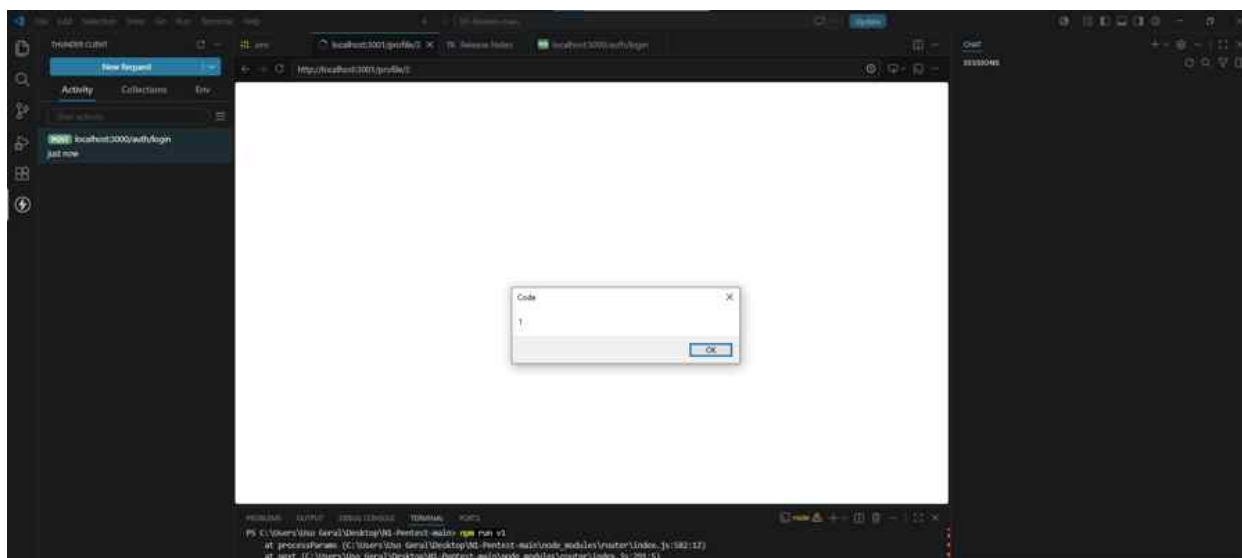


Figura 2 - Stored XSS com execução de JavaScript.

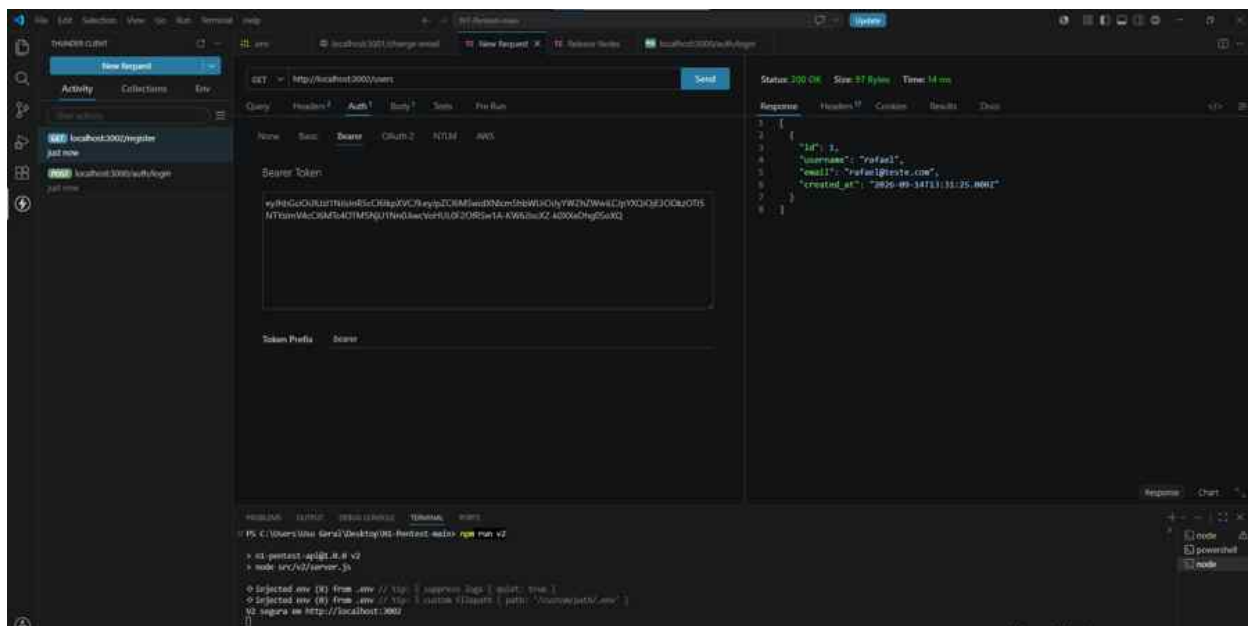


Figura 5 - GET /users autenticado com JWT.

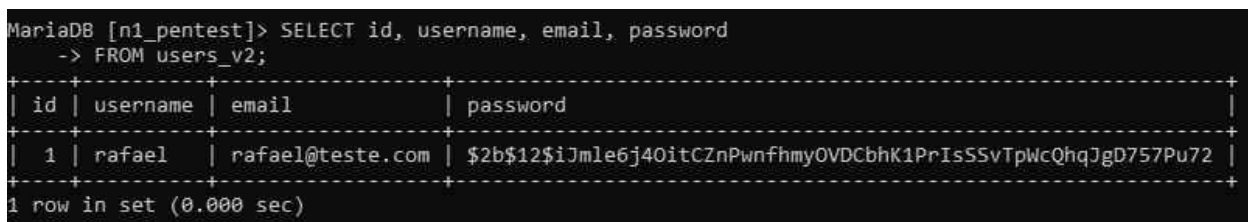


Figura 6 - Senha armazenada como hash bcrypt.

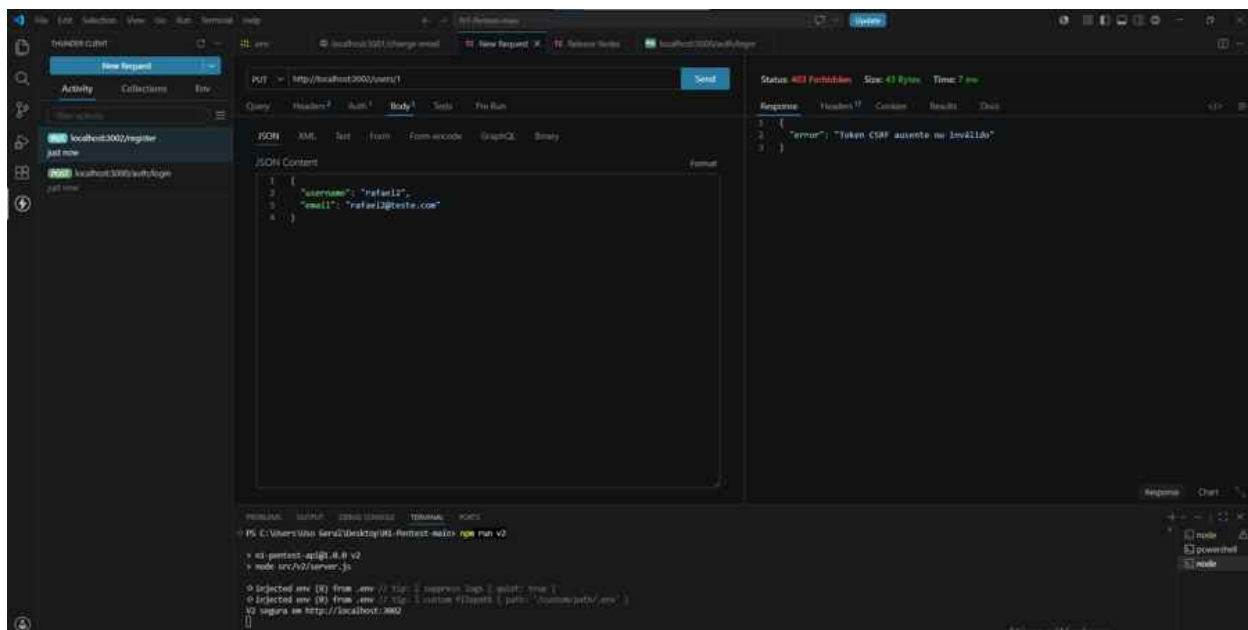


Figura 7 - Operação sensível bloqueada sem token CSRF.

Conclusão

Os testes realizados exclusivamente em localhost comprovaram as falhas solicitadas na V1 e os controles principais da V2.